AUTHENTICATION AND ACCESS CONTROL

Course: Diploma in Cyber Security

Name: HET ACHARYA

Introduction

Authentication checks who a user is, while access control checks what that user is allowed to do. A simple login system can demonstrate these ideas before they are used in a real application.

Task 1: Mock Zomato admin login

Create a small login form with username and password fields. Compare the entered values with hardcoded lab credentials. If both values match, display 'Access Granted'; otherwise display 'Access Denied'.



Figure: Mock Zomato Admin Authentication Form Displaying Successful "Access Granted" Execution

Task 2: Role-based access function

A dictionary can store which resources each role can use. The function returns True when the requested resource is in that role's allowed list.

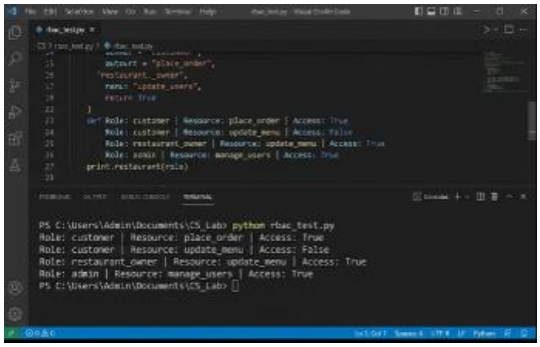


Figure: Output of the Role-Based Access Control (RBAC) Verification Function

Task 3: Two-factor authentication

After the correct password is entered, generate a 6-digit OTP. Ask the user to enter the OTP. Only show 'Login Successful' when the entered OTP matches the generated value.

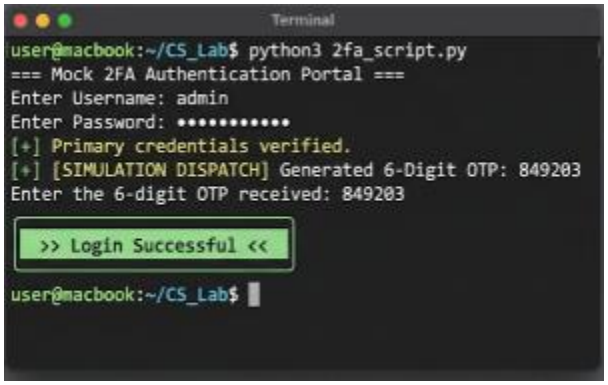


Figure: Successful Test Run of the Multi-Factor Authentication (2FA) Script

Task 4: Premium user filter

Check each user object and keep only users who are premium and whose last login date is within the last 7 days. For the task, use the given date of 2024-06-10 as today.

Task 5: Common access control mistakes

Examples include giving users more permissions than needed, checking permissions only on the client side, using predictable roles, forgetting to check access on every sensitive action, and exposing admin functions to normal users. A simple fix is to enforce permissions on the server side and follow least privilege.

Conclusion

This topic helped me understand the basic concept and how it can be used in a real network. I also understood that practical results should be checked on the actual system or simulator instead of assuming the result.